

LOGIMARKET.EU

DPO / Privacy Compliance Final Decision Record

LogiMarket Marketplace B2B - finalny wewnętrzny record privacy, role RODO, retencja, cookies, vendor/DPA/SCC/TIA i warunki wdrożeniowe.

STATUS: APPROVED WITH CONDITIONS. Privacy architecture została zweryfikowana; implementacyjne evidence pozostaje otwarte. Dokument nie uruchamia zmian w kodzie ani bazie danych.

Gate / pole	Stan
PRIVACY_COUNSEL_REVIEW	RECEIVED / APPROVED_WITH_CONDITIONS
FORMAL_IOD_REQUIRED_CURRENT_MVP	NO - re-screening przy zmianie zakresu
LEG-MKT-09	APPROVED_WITH_CONDITIONS
OMQ-MKT-11	APPROVED_WITH_CONDITIONS
DPO_ARCHITECTURAL_BLOCKER_FOR_56B1	CLEARED
LM_MARKETPLACE_SCHEMA_56B1_READY	NO - Tax/DAC7 + Owner/Engineering Readiness nadal otwarte

Hierarchia: obowiązujące prawo i najnowsze oficjalne źródła vendora > finalne ustalenia Privacy Counsel > niniejszy record > wcześniejsze drafty/analizy. W razie konfliktu nie używać superseded fragmentów.

1. Executive decision

PRIVACY_COUNSEL_REVIEW_RECEIVED=YES
PRIVACY_COUNSEL_VERDICT=APPROVED_WITH_CONDITIONS

FORMAL_IOD_REQUIRED_CURRENT_MVP=NO
IOD_RESCREEN_REQUIRED_ON_SCOPE_CHANGE=YES

LEG_MKT_09=APPROVED_WITH_CONDITIONS
OMQ_MKT_11=APPROVED_WITH_CONDITIONS

DPO_ARCHITECTURE_REVIEW=PASS
DPO_IMPLEMENTATION_EVIDENCE=OPEN

DPO_ARCHITECTURAL_BLOCKER_FOR_56B1=CLEARED
TAX_DAC7_BLOCKER=OPEN
OWNER_ENGINEERING_READINESS=OPEN
LM_MARKETPLACE_SCHEMA_56B1_READY=NO

1.1 Co jest rozstrzygnięte

- LogiMarket jest administratorem obecnych operacji ACT-01...ACT-06 w zakresie, w jakim sam ustala ich cele i zasadnicze środki.
- Supabase pełni rolę procesora dla danych klienta przetwarzanych w ramach bazy/Auth, zgodnie z aktualnym DPA.
- Nie należy globalnie hardcodować Partnera jako procesora ani współadministratora. Rola Partnera jest ustalana per operacja po zaprojektowaniu faktycznego transferu danych.
- Zgoda nie jest podstawą core checkout/RFQ. Obecny `rfqLabels.consent` powinien zostać zastąpiony warstwową informacją art. 13 RODO.
- Dla MVP rekomendowany jest koszyk oparty o cookie ściśle niezbędne do sesji; jeśli Owner zachowuje trwałe pamiętanie koszyka, wymagana jest osobna kwalifikacja art. 399 PKE i - jeśli brak wyjątku z art. 399 ust. 3 - mechanizm zgody.
- Primary database region Supabase jest w EOG: `eu-west-1`, West EU (Ireland). Nie oznacza to jednak braku transferów poza EOG.
- Aktualny Supabase DPA zawiera SCC 2021/914 i nie wymaga odrębnego podpisu SCC, ponieważ akceptacja Agreement ma skutek podpisania SCC.
- Transfery/onward transfers poza EOG są możliwe i muszą być ujawniane oraz kontrolowane w vendor register.
- DPIA nie jest wymagana dla obecnego MVP przy aktualnych faktach, ale screening musi być ponowiony przy zmianie ryzyka/skali/funkcji.

1.2 Co pozostaje warunkiem wdrożeniowym

RFQ_CONSENT_REMOVAL=NOT_IMPLEMENTED
ART13_FINAL_UI_NOTICE=NOT_IMPLEMENTED
COOKIE_SECURE_FLAG=NOT_VERIFIED
CART_COOKIE_PRODUCT_DECISION=OPEN
RETENTION_ENFORCEMENT=NOT_IMPLEMENTED
LIA_ACT04=NOT_EVIDENCED
LIA_ACT06=NOT_EVIDENCED
PRIVACY_MAILBOX=NOT_VERIFIED
INTERNAL_VENDOR_REGISTER=OPEN
CURRENT_SUPABASE_TIA_REFRESH=REQUIRED_BEFORE_GO_LIVE_OR_PERIODIC_VENDOR_REVIEW
PARTNER_ART26_OR_C2C=FUTURE_BEFORE_FIRST_PRODUCTION_PII_TRANSFER

2. Screening obowiązku formalnego wyznaczenia IOD - art. 37 RODO

2.1 Werdykt

FORMAL_IOD_REQUIRED_CURRENT_MVP = NO, na podstawie obecnych faktów i z zastrzeżeniem re-screeningu.

Aktualny MVP nie zakłada jako głównej działalności:

- regularnego i systematycznego monitorowania osób na dużą skalę;
- przetwarzania na dużą skalę szczególnych kategorii danych z art. 9 RODO lub danych z art. 10;
- automatycznego profilowania/scoringu użytkowników na dużą skalę.

2.2 Model operacyjny

LogiMarket może korzystać z zewnętrznego Privacy Counsel / privacy advisor bez formalnego wyznaczenia tej osoby jako IOD. Komunikacja publiczna nie powinna jednak sugerować istnienia formalnego IOD, jeżeli nie został on wyznaczony zgodnie z art. 37-39 RODO.

Kontakt rekomendowany: privacy@logimarket.eu - do uruchomienia i weryfikacji przed publikacją polityki prywatności.

2.3 Triggery ponownego screeningu

Ponowny screening jest wymagany co najmniej przy:

1. wdrożeniu profilowania behawioralnego lub zautomatyzowanego scoringu;
2. istotnym wzroście skali monitorowania użytkowników;
3. wejściu w B2C, jeżeli zmienia skalę/profil ryzyka;
4. rozpoczęciu przetwarzania danych szczególnych kategorii lub danych z art. 10;
5. istotnej zmianie architektury danych lub dostawców.

3. ROPA - Rejestr Czynności Przetwarzania ACT-01...ACT-06

ACT-01 - Checkout / order submission

Pole	Decyzja finalna
Cel	Przyjęcie order intent / obsługa procesu prowadzącego do zawarcia umowy Partner-Kupujący; bezpieczeństwo i dowodowość platformy
Kategorie osób	JDG jako osoba fizyczna; pracownik/reprezentant przedsiębiorcy; osoba kontaktowa
Dane	companyName; contactName; email; phone jeśli wymagany/wybrany; message; order items; wartość/parametry zamówienia; identyfikatory techniczne
Rola LogiMarket	Administrator
Podstawa - JDG będąca stroną	art. 6 ust. 1 lit. b RODO - w zakresie niezbędnym do kroków na żądanie osoby przed zawarciem umowy / obsługi relacji umownej
Podstawa - pracownik/reprezentant	art. 6 ust. 1 lit. f RODO - uzasadniony interes w obsłudze transakcji B2B
Odbiorcy CURRENT	Upoważniony personel LogiMarket; Supabase jako procesor infrastrukturalny
Odbiorcy FUTURE	Partner/Sprzedawca po uruchomieniu routingu PII i po ustaleniu roli per operacja
Informacja	Art. 13 przy kolekcji; wskazanie kategorii/konkretnego Partnera jako odbiorcy zgodnie z finalnym UI
Retencja target	do 3 lat dla PII potrzebnego do roszczeń platformowych, z uwzględnieniem przepisów szczególnych; dane księgowe wyłącznie w zakresie obowiązku prawnego

ACT-02 - RFQ

Pole	Decyzja finalna
Cel	Obsługa zapytania ofertowego i negocjacji; routing do Partnera po uruchomieniu funkcji
Kategorie osób	JDG; pracownik/reprezentant firmy
Dane	companyName; contactName; email; phone; message; offerId/partner context
Rola LogiMarket	Administrator
Podstawa - JDG	art. 6 ust. 1 lit. b RODO - kroki przed zawarciem umowy na żądanie osoby
Podstawa - pracownik/reprezentant	art. 6 ust. 1 lit. f RODO
Zgoda	NIE dla core RFQ
P0	rfqLabels.consent zastąpić informacją art. 13; osobny checkbox tylko dla odrębnego celu wymagającego zgody, np. przyszłego marketingu
Retencja target	12 miesięcy od ostatniej uzasadnionej aktywności, chyba że RFQ przechodzi do transakcji/roszczenia wymagającego innej retencji

ACT-03 - Admin authentication & authorization

Pole	Decyzja finalna
Cel	Uwierzytelnienie, kontrola dostępu, bezpieczeństwo administracyjne
Dane	email; identyfikator użytkownika; metadane auth; IP/logi; credential przetwarzany przez Supabase Auth zgodnie z usługą vendor
Rola LogiMarket	Administrator
Rola Supabase	Procesor
Podstawa	art. 6 ust. 1 lit. f RODO; w określonych relacjach także właściwa podstawa zatrudnienia/współpracy
Retencja target	konto przez okres uprawnienia + kontrolowany offboarding; logi bezpieczeństwa wg udokumentowanego okresu, target 12 miesięcy podlegający security review

ACT-04 - Outbound clicks / attribution

Pole	Decyzja finalna
Cel	Atrybucja prowizji/success fee, bezpieczeństwo i przeciwdziałanie nadużyciom

Pole	Decyzja finalna
Dane	session identifier; HMAC-SHA256(IP) lub równoważny pseudonim; offerId; partnerId; timestamp
Klasyfikacja	Dane pseudonimizowane, nie anonimowe, jeśli istnieje realna możliwość powiązania z osobą/session
Rola LogiMarket	Administrator
Procesor	Supabase, jeśli zdarzenia są utrwalane w projekcie DB; brak odrębnego third-party analytics vendora w założonym modelu
Podstawa	art. 6 ust. 1 lit. f RODO + pisemny LIA
Retencja target	12 miesięcy dla raw attribution evidence; następnie anonimizacja/usunięcie identyfikatorów, jeśli brak innej podstawy

ACT-05 - Cart & session

Pole	Decyzja finalna
Cel	Funkcjonalność koszyka i ciągłość sesji
Dane	losowy session ID; cart items; niezbędne metadane techniczne
Rola LogiMarket	Administrator
Procesor	Supabase dla rekordów przechowywanych w projekcie DB
RODO	art. 6 ust. 1 lit. b i/lub f - zależnie od konkretnego celu i relacji
Terminal storage	art. 399 PKE
Policy target	preferowane session-only dla ściśle niezbędnego koszyka; persistence między wizytami wymaga osobnej oceny i, gdy wyjątek art. 399 ust. 3 nie działa, zgody

ACT-06 - Partner contacts / KYB contact layer

Pole	Decyzja finalna
Cel	Zarządzanie relacją B2B, onboarding/KYB, kontakt operacyjny
Osoby	Reprezentant/pracownik Partnera; JDG jeśli Partnerem jest osoba fizyczna prowadząca działalność
Dane	companyName; contactEmail; websiteUrl; dane kontaktowe i niezbędne dane identyfikacyjne osoby
Rola LogiMarket	Administrator

Pole	Decyzja finalna
Podstawa	art. 6 ust. 1 lit. f RODO; art. 6 ust. 1 lit. b tylko gdy dana osoba jest stroną odpowiedniej umowy i przetwarzanie jest niezbędne
Public vs internal	rozdzielić publiczny seller profile od wewnętrznego KYB; nie publikować automatycznie danych rozszerzonego KYB
LIA	wymagany dla przetwarzania opartego o art. 6 ust. 1 lit. f

4. Role RODO przy przyszłym przekazywaniu danych do Partnera

4.1 Zasada nadrzędna

Nie przypisujemy jednej roli RODO całej relacji LogiMarket-Partner. Role określa się **per processing operation** na podstawie rzeczywistych celów i zasadniczych środków, zgodnie z EDPB Guidelines 07/2020.

4.2 Drzewo decyzyjne

1. Jeżeli Partner działa wyłącznie na udokumentowane polecenie LogiMarket i nie realizuje własnego celu - relacja może być art. 28 RODO. **Nie jest to zakładany model Seller of Record.**
2. Jeżeli obie strony wspólnie determinują cel i zasadnicze środki określonej fazy zbierania/routingu - dla tej fazy może powstać współadministrowanie art. 26.
3. Jeżeli LogiMarket samodzielnie prowadzi kolekcję, a Partner po otrzymaniu danych realizuje własny cel sprzedaży - możliwy jest model dwóch niezależnych administratorów z klauzulami C2C.

4.3 Warunek przed pierwszym produkcyjnym transferem PII do Partnera

```
PARTNER_DATA_FLOW_DESIGN=REQUIRED
ROLE_ASSESSMENT_PER_OPERATION=REQUIRED
ART26_OR_C2C_DOCUMENT=REQUIRED_AS_APPLICABLE
ART13_NOTICE_UPDATED=REQUIRED
PARTNER_ART14_ASSESSMENT=REQUIRED
DPO_REVIEW_BEFORE_FIRST_TRANSFER=REQUIRED
```

4.4 Art. 14 - ważna normalizacja

Partner, który otrzymuje dane nie bezpośrednio od osoby, samodzielnie ocenia obowiązek z art. 14 RODO. Wyjątek art. 14 ust. 5 lit. a może być stosowany **wyłącznie w takim zakresie, w jakim osoba już posiada wszystkie wymagane informacje**. Samo przekazanie Partnerowi noty przez LogiMarket nie tworzy automatycznego zwolnienia.

5. Obowiązek informacyjny art. 13 - model finalny

5.1 Warstwa 1 - UI formularza

Checkout - wzorzec:

Administratorem danych osobowych zbieranych przez platformę jest podmiot prowadzący LogiMarket wskazany w Polityce Prywatności. Dane wykorzystujemy do obsługi procesu zamówienia, bezpieczeństwa platformy i - gdy funkcja jest aktywna - przekazania danych właściwemu Sprzedawcy w celu obsługi transakcji. Szczegóły, podstawy prawne, odbiorcy, transfery i prawa użytkownika opisuje Polityka Prywatności.

RFQ - wzorzec zastępujący consent:

Dane z formularza RFQ wykorzystujemy do obsługi zapytania i - gdy routing do Partnera jest aktywny - przekazania

danych wybranemu Partnerowi w celu przygotowania odpowiedzi handlowej. Szczegóły znajdują się w Polityce Prywatności.

5.2 Warstwa 2 - Polityka Prywatności

Finalna polityka przed publikacją musi zawierać co najmniej:

- dokładną nazwę prawną administratora, adres i dane kontaktowe;
- kontakt privacy; kontakt IOD wyłącznie jeśli formalny IOD zostanie wyznaczony;
- cele i podstawy osobno dla JDG będącej stroną oraz pracowników/reprezentantów;
- uzasadnione interesy dla art. 6 ust. 1 lit. f;
- odbiorców/kategorie odbiorców, w tym Partnera i dostawców infrastruktury;
- prawdziwy opis transferów poza EOG;
- okresy lub kryteria retencji;
- prawa osób, w tym sprzeciw dla art. 6 ust. 1 lit. f;
- prawo wniesienia skargi do Prezesa UODO;
- informację o obowiązkowości/nieobowiązkowości pól;
- informacje o zautomatyzowanym podejmowaniu decyzji, jeżeli takie funkcje powstaną.

OWNER_FACT_REQUIRED przed publikacją: dokładna firma administratora, adres, NIP/KRS jeśli używane w notice, aktywny adres privacy@logimarket.eu (lub inny zatwierdzony privacy contact).

6. Cookie / terminal storage - art. 399 PKE

6.1 Stan prawny

Art. 399 PKE wymaga uprzedniej informacji i zgody dla przechowywania informacji lub uzyskiwania dostępu do informacji w urządzeniu końcowym, z wyjątkiem sytuacji z ust. 3, w szczególności gdy jest to konieczne do dostarczenia usługi świadczonej drogą elektroniczną żądanej przez użytkownika.

6.2 Decyzja privacy dla koszyka

Wariant	Ocena	Status
Session-only cookie niezbędne do bieżącego koszyka	Może korzystać z wyjątku art. 399 ust. 3 pkt 2, pod warunkiem realnej konieczności i braku dodatkowego celu	RECOMMENDED_FOR_MVP
Trwałe pamiętanie koszyka między wizytami	Nie uznawać automatycznie za ściśle niezbędne; wykonać odrębną ocenę. Jeśli wyjątek nie działa - aktywna zgoda przed zapisaniem/odczytem	OWNER_PRODUCT_DECISION_REQUIRED

Nie istnieje bezpieczna reguła typu **24h = zawsze bez zgody**. Decyduje funkcjonalna konieczność względem usługi żądanej przez użytkownika.

6.3 Security P0

Produkcyjne cookie sesyjne powinno mieć co najmniej:

```
Secure
HttpOnly
SameSite=Lax    # o ile model integracji nie wymaga innego ustawienia
Path=/          # jeśli właściwe dla zastosowania
HTTPS only
```

Prefiks **__Host-** można rozważyć, jeżeli spełnione są jego techniczne wymagania i nie powoduje to regresji obecnego mechanizmu sesji. **Secure** i HTTPS/HSTS wymagają bezpośredniej weryfikacji Engineering/Browser QA przed PASS.

7. Retencja - finalny policy target

Okresy poniżej są zatwierdzonymi targetami privacy, a nie automatycznym upoważnieniem do zmian schematu/SQL. Mechanizm egzekwowania zostanie zaprojektowany w odpowiednim scope (najpóźniej 56B6) z uwzględnieniem faktycznego modelu danych, backupów i wymogów podatkowych.

Dataset	Target	Trigger	Akcja	Uwagi
cart_items porzucone	session-only albo okres zgodny z zatwierdzonym persistence mode	koniec sesji / ostatnia aktywność	delete	Nie utrzymywać 30 dni, jeśli finalny model produktu przejdzie na session-only
rfq_leads nieaktywne	12 miesięcy	ostatnia uzasadniona aktywność	delete/anonymize	wyjątek dla sporu/roszczenia lub konwersji do transakcji
orders - PII platformowe	target do 3 lat	finalny status / ostatnie zdarzenie roszczeniowe	anonimizacja/minimalizacja	3 lata to target dla własnych roszczeń platformowych, nie uniwersalny termin dla wszystkich roszczeń B2B; stosować przepisy szczególne, gdy mają zastosowanie
dane księgowe/podatkowe	zgodnie z aktualnym obowiązkiem prawnym	właściwy trigger ustawowy	archiwizacja ograniczonego datasetu	nie przechowywać całego PII tylko dlatego, że część danych ma wymóg księgowy
clicks raw	12 miesięcy	timestamp	anonimizacja/delete identyfikatorów	uzasadnić w LIA i success-fee evidence policy
admin auth/logs	konto do offboardingu; logi target 12 miesięcy	utrata roli / timestamp	revoke/delete wg security policy	okres logów podlega security review
partner contacts	współpraca + target do 3 lat dla roszczeń	zakończenie relacji	minimalizacja/delete	osobno dane księgowe i osobno marketing

7.1 Wymagania techniczne

- retention enforcement ma być automatyczny i audytowalny;
- brak bezterminowego soft-delete jako substytutu usunięcia;
- backup retention musi być udokumentowany osobno;
- operacje retencji muszą mieć audit evidence;
- metoda techniczna jest wybierana przez Engineering w repozytorium - dokument nie autoryzuje Supabase Edge Functions ani innych nowych backendów.

8. Supabase - vendor due diligence i transfery

8.1 Region projektu

Evidence z dashboardu Supabase potwierdza:

Project region
West EU (Ireland)

eu-west-1

Copy

Save changes

Evidence E1 - Supabase Project Settings: eu-west-1, West EU (Ireland), 9.08.2026.

```
PROJECT_REGION=eu-west-1
DISPLAY_REGION=West EU (Ireland)
PRIMARY_DATABASE_REGION_EEA=PASS
```

Jest to primary storage region projektu, a nie dowód, że wszystkie operacje wszystkich subprocesorów są wykonywane wyłącznie w EOG.

8.2 DPA

Aktualny oficjalny Supabase Data Processing Addendum:

```
DPA_VERSION=Version 1 - August 1, 2026
DPA_FORMS_PART_OF_SUPABASE_AGREEMENT=YES
SEPARATE_DPA_SIGNATURE_REQUIRED=NO_AS_DEFAULT_CONTRACT_MECHANISM
SUPABASE_ROLE=PROCESSOR/SERVICE_PROVIDER_FOR_CUSTOMER_COVERED_DATA
```

DPA stanowi część Agreement i jest skuteczny od Effective Date Agreement. Dla transferów objętych GDPR DPA inkorporuje SCC 2021/914; przy modelu Customer controller → Supabase processor stosuje Module Two. Akceptacja Agreement ma skutek podpisania SCC.

Operational evidence condition: zachować snapshot aktualnego DPA oraz dowód relacji kontraktowej/konta, na podstawie którego Agreement obowiązuje LogiMarket.

8.3 Subprocesorzy

Oficjalna strona Supabase wskazuje listę z aktualizacją **1 czerwca 2026 r.** i mechanizm subskrypcji zmian. Wewnętrzny LogiMarket Vendor Register musi utrzymywać:

- vendor/service;
- rolę privacy;
- zakres danych;
- lokalizację/transfery;
- wersję DPA/subprocessor list;
- datę review;
- owenera i termin kolejnego review.

```
SUPABASE_SUBPROCESSOR_SOURCE=VERIFIED
INTERNAL_VENDOR_REGISTER=OPEN
CHANGE_NOTIFICATION_SUBSCRIPTION=RECOMMENDED
```

8.4 Transfery poza EOG

Nie wolno używać w polityce zdania **Brak transferu poza EEA**.

Aktualny DPA zezwala Supabase na przetwarzanie w lokalizacjach, w których Supabase lub subprocesorzy utrzymują infrastrukturę, przy zachowaniu mechanizmów transferowych. Dane skierowane do konkretnego regionu mają być tam przechowywane i głównie przetwarzane, ale DPA nie gwarantuje globalnego EEA-only processing.

Finalny status:

```
PRIMARY_DB_STORAGE=EEA_IRELAND
THIRD_COUNTRY_TRANSFERS=YES/POSSIBLE_UNDER_VENDOR_CHAIN
SCC_2021_914=INCORPORATED
TRANSFER_DISCLOSURE_IN_PRIVACY_NOTICE=REQUIRED
```

Publiczna polityka powinna wskazywać, że dane mogą być przetwarzane poza EOG i że stosowane są mechanizmy z rozdziału V RODO, np. decyzja adequacy, SCC lub inna właściwa podstawa - zgodnie z faktycznym vendor register.

8.5 TIA - status evidence

Załączony Supabase TIA jest datowany na **14 marca 2025 r.** i opisuje m.in. USA, Singapur, FISA 702/EO 12333, SCC Module Two i środki techniczne. Dokument jest użytecznym evidence historycznym, ale nie jest wystarczający jako jedyny aktualny TIA na 2026 r., ponieważ:

- jest starszy od aktualnego DPA z 1 sierpnia 2026 r.;
- jest starszy od aktualnej listy subprocessorów z 1 czerwca 2026 r.;
- w nagłówku identyfikuje data importera jako Supabase Inc w Delaware, podczas gdy aktualny DPA w Schedule 2 wskazuje Supabase Pte. Ltd w Singapurze jako data importera dla SCC.

Dlatego:

```
SUPABASE_VENDOR_TIA=AVAILABLE
TIA_DATE=2025-03-14
TIA_CURRENT_ALIGNMENT=REFRESH_REQUIRED
TIA_REFRESH_BLOCKS_56B1=NO
TIA_REFRESH_REQUIRED_BEFORE_GO_LIVE_OR_PERIODIC_VENDOR_REVIEW=YES
```

9. DPIA Screening - art. 35 RODO

9.1 Werdykt

```
DPIA_SCREENING=PASS
DPIA_REQUIRED_CURRENT_MVP=NO
```

Obecny model nie wskazuje na zestaw okoliczności tworzących wysokie ryzyko wymagające DPIA, w szczególności brak szczególnych kategorii danych na dużą skalę i brak automatycznego profilowania użytkowników na dużą skalę.

9.2 Obowiązkowy re-screening

Przy:

- automatycznym scoringu/rankingu osób/Partnerów mogącym istotnie wpływać na osoby;
- behawioralnym profilowaniu użytkowników;
- nowych wrażliwych kategoriach danych;
- istotnym zwiększeniu skali systematycznego monitorowania;
- znaczącej zmianie PSP/payment data architecture;
- nowej technologii lub innym istotnym wzroście ryzyka.

10. LIA - wymagane testy uzasadnionego interesu

Przed go-live należy zatwierdzić co najmniej dwa pisemne LIA:

LIA-01 - ACT-04 Outbound attribution

- interest: rozliczenie success fee, dowodowość, antifraud;
- necessity: minimalizacja danych i brak third-party tracking;
- balancing: pseudonimizacja, ograniczona retencja, brak reklamowego profilowania;
- safeguards: HMAC/key management, access control, retention, Art. 13, Art. 21 handling.

LIA-02 - ACT-06 Partner contacts

- interest: obsługa relacji B2B/KYB i komunikacja operacyjna;
- necessity: minimalny kontakt reprezentanta;
- balancing: oczekiwania w relacji zawodowej, brak wtórnego marketingu bez osobnej analizy;
- safeguards: access controls, offboarding, minimalizacja, sprzeciwi.

LIA_ACT04=OPEN
LIA_ACT06=OPEN

11. DSAR - procedura art. 12-23 RODO

Kanały

- privacy@logimarket.eu po aktywacji;
- poczta na oficjalny adres administratora;
- future self-service tylko po zatwierdzeniu security/privacy.

Weryfikacja tożsamości

Stosować proporcjonalną weryfikację zgodnie z art. 12 ust. 6. Nie zbierać nadmiarowych dokumentów tożsamości, jeżeli żądanie można zweryfikować mniej inwazyjnie.

Terminy

Odpowiedź bez zbędnej zwłoki, co do zasady w ciągu miesiąca. Przy złożoności/liczbie żądań możliwe przedłużenie o kolejne dwa miesiące z informacją przekazaną w pierwszym miesiącu.

Koszt

Żądania są co do zasady bezpłatne. Opłata lub odmowa jest możliwa wyłącznie przy żądaniach ewidentnie nieuzasadnionych lub nadmiernych, w szczególności ze względu na ustawiczny charakter.

Minimalny case register

- request ID/date;
- osoba i sposób weryfikacji;
- zakres praw;
- systemy/dataset objęte żądaniem;
- decyzja i wyjątki;
- data odpowiedzi;
- dowód wykonania.

12. Naruszenia danych - art. 33/34 RODO

12.1 Workflow

Etap	Wymaganie
Detection	natychmiastowa eskalacja do privacy/security ownera
Risk assessment	ustalić rodzaj danych, skalę, skutki, środki ograniczające i prawdopodobieństwo ryzyka
UODO	zgłoszenie bez zbędnej zwłoki, w miarę możliwości ≤72h od stwierdzenia, gdy naruszenie może powodować ryzyko dla praw i wolności
Data subjects	bez zbędnej zwłoki, gdy naruszenie może powodować wysokie ryzyko i nie zachodzi wyjątek art. 34
Record	każde naruszenie dokumentować zgodnie z art. 33 ust. 5

12.2 Supabase

Aktualny DPA zobowiązuje Supabase do pisemnego powiadomienia Customer bez zbędnej zwłoki i - gdy wykonalne - w ciągu 48 godzin od uzyskania wiedzy o Security Incident. Jest to vendor SLA/evidence input, ale nie zmienia odpowiedzialności LogiMarket za własny termin art. 33 RODO.

13. Security / privacy by design - wymagania przed go-live

Minimalne wymagania privacy/security dla zakresu objętego dokumentem:

- server-authoritative authorization i least privilege;
- `requireAdmin` bez bypassów;
- produkcyjne cookie `Secure`, `HttpOnly`, właściwe `SameSite`;
- HTTPS + potwierdzona polityka HSTS;
- brak sekretów/PII w logach aplikacyjnych bez wyraźnej potrzeby;
- kontrola dostępu do RFQ/orders/partner contact PII;
- udokumentowane retention jobs;
- rejestr vendorów i wersji DPA/subprocessors;
- incident register i DSAR register;
- LIA dla ACT-04 i ACT-06;
- przegląd free-text `message` pod kątem minimalizacji i ostrzeżenia przed podawaniem danych zbędnych/wrażliwych;
- ponowny privacy review przy PSP/Partner Portal/B2C/automated ranking.

PASS w tych obszarach wymaga bezpośredniej evidence zgodnie z projektem; brak evidence = NOT_TESTED/OPEN, nie PASS.

14. Implementation conditions i gate closure

14.1 Privacy gates

```
LEG_MKT_09=APPROVED_WITH_CONDITIONS
OMQ_MKT_11=APPROVED_WITH_CONDITIONS
DPO_ARCHITECTURE_REVIEW=PASS
DPO_IMPLEMENTATION_EVIDENCE=OPEN
```

14.2 Conditions before production

1. Finalne dane administratora i działający privacy contact.
2. Zastąpienie `rfqLabels.consent` warstwowym Art. 13 notice.
3. Finalne Art. 13/Privacy Policy obejmujące third-country transfers.
4. Engineering evidence produkcyjnego `Secure` cookie + HTTPS/HSTS.
5. Owner decision: session-only cart albo persistence z prawidłowym mechanizmem art. 399 PKE.
6. Retention enforcement i audit evidence dla datasetów objętych policy.
7. LIA ACT-04 i ACT-06.
8. Wewnętrzny Vendor Register i subprocessor change monitoring.
9. TIA refresh/confirmation against current 2026 Supabase DPA/subprocessor chain w ramach go-live/periodic vendor review.
10. Art. 26/C2C + Art. 13/14 assessment przed pierwszym rzeczywistym production PII transfer do Partnera.
11. DSAR i breach procedures operationalized.

14.3 56B1

```
DPO_ARCHITECTURAL_BLOCKER_FOR_56B1=CLEARED
TAX_DAC7_BLOCKER=OPEN
OWNER_ENGINEERING_READINESS=OPEN
LM_MARKETPLACE_SCHEMA_56B1_READY=NO
```

Privacy PO przed go-live nie powinien być przypadkowo dokładany do sprintu 56B1, jeżeli nie należy do jego scope. Odpowiednie zmiany UI/security/retention powinny zostać zaplanowane w osobnych, autoryzowanych sprintach.

15. Evidence register

ID	Evidence	Status / znaczenie
E1	Screenshot Supabase Project Settings, 9.08.2026	eu-west-1, West EU (Ireland) - primary project region confirmed
E2	Supabase DPA, Version 1 - August 1, 2026	DPA part of Agreement; processor role; SCC; acceptance of Agreement equivalent to SCC signature
E3	Supabase official Subprocessor List	Updated June 1, 2026; change subscription available
E4	Supabase+TIA+250314-1.pdf	TIA dated 14.03.2025; USA/Singapore/onward transfer analysis; refresh required against 2026 DPA/entity/subprocessors
E5	logimarket_pakiet_dpo_v1.0_draft.md	Source draft for ACTs, ROPA, notices, retention, cookie, DPA, roles, DPIA, DSAR, breach, Art.26
E6	LogiMarket GDPR/Data Flow Pack	Technical fact inventory and pending/privacy decisions supporting ACT-01...ACT-06

16. Źródła prawne i oficjalne

[S1] RODO / GDPR: Rozporządzenie (UE) 2016/679, w szczególności art. 5, 6, 12-14, 21, 26, 28, 30, 32-35, 37-39, 44-49. Oficjalny EUR-Lex. **[S2] PKE:** Ustawa z 12 lipca 2024 r. - Prawo komunikacji elektronicznej, Dz.U. 2024 poz. 1221, art. 399-400. Oficjalny ELI. **[S3] KC:** Kodeks cywilny, tekst jednolity Dz.U. 2026 poz. 795, w szczególności art. 118 i właściwe przepisy szczególne dotyczące przedawnienia. Oficjalny ELI. **[S4] EDPB Guidelines 07/2020:** concepts of controller and processor in the GDPR. **[S5] EDPB Recommendations 01/2020:** measures supplementing transfer tools. **[S6] Supabase DPA:** <https://supabase.com/legal/customer-resources/data-processing-addendum>, Version 1 - August 1, 2026. **[S7] Supabase Subprocessor List:** <https://supabase.com/legal/customer-resources/subprocessor-list>, updated June 1, 2026. **[S8] Supabase TIA:** customer-provided PDF dated 14 March 2025.

17. Final status record

PRIVACY_WORKSTREAM_SUBSTANTIVE_REVIEW=CLOSED_WITH_CONDITIONS
 FORMAL_IOD_REQUIRED_CURRENT_MVP=NO
 IOD_RESCREEN_REQUIRED=YES_ON_TRIGGER

ROPA_DESIGN=APPROVED_WITH_CORRECTIONS
 ART13_MODEL=APPROVED_WITH_IMPLEMENTATION_REQUIRED
 COOKIE_POLICY=APPROVED_AS_DECISION_FRAMEWORK
 RETENTION_POLICY=APPROVED_AS_TARGET
 SUPABASE_PRIMARY_REGION_EEA=PASS
 SUPABASE_DPA=VERIFIED
 SUPABASE_SCC=VERIFIED
 SUPABASE_SUBPROCESSOR_SOURCE=VERIFIED
 SUPABASE_TIA=AVAILABLE_REFRESH_REQUIRED
 THIRD_COUNTRY_TRANSFERS=YES
 DPIA_REQUIRED_CURRENT_MVP=NO

LEG_MKT_09=APPROVED_WITH_CONDITIONS
 OMO_MKT_11=APPROVED_WITH_CONDITIONS
 DPO_ARCHITECTURAL_BLOCKER_FOR_56B1=CLEARED

```
LM_MARKETPLACE_SCHEMA_56B1_READY=NO  
NEXT_EXTERNAL_GATE=TAX_DAC7  
NEXT_INTERNAL_GATE=OWNER_ENGINEERING_READINESS
```

Owner Review boundary: niniejszy dokument kończy konsolidację privacy na poziomie architektonicznym. Nie uruchamia automatycznie zmian w kodzie, DB, migracji ani produkcji.

FINAL: Privacy architecture jest zamknięta warunkowo. Dalsze działania wymagają osobnych sprintów/evidence; niniejszy dokument nie autoryzuje mutacji DB, zmian schematu ani produkcyjnych zapisów.